Event Schema and API Spec

The contract between agents, gateway, detector and dashboard

1. Purpose

Defines the one event format every component uses and the HTTP API the gateway exposes. Freeze this in Phase 0; changes after that need a version bump (v1 to v2).

2. Event schema (v1)

Field	Type	Description
event_id	uuid	Unique per tool call
ts	ISO 8601 UTC	Time the call was received
agent_id	string	Stable agent identity (the credential owner)
role	string	Declared role, matches a manifest name
session_id	string	One run of the agent; isolation applies at this level
tool	string	Tool or API called
action	enum	read, write, delete, send, execute
resource	string	Path, URL or record identifier touched
data_class	string	supplier, pricing, hr, payroll, finance, public, unknown
sensitivity	int 0-3	0 public, 1 internal, 2 confidential, 3 restricted
destination	string or null	Host for outbound calls; null for internal reads
bytes_out	int	Payload size sent out
taint	list	Untrusted sources the context has read: [{source, ts, kind}]
chain	list	Delegation chain, caller first: [agent_A, agent_B]
manifest_version	int	Manifest version in force at call time
token_id	string	Token identifier (never the token itself)

3. Example event

```
{
  "event_id": "7c1e...", "ts": "2026-10-23T08:12:41Z",
  "agent_id": "procurement-bot-04", "role": "procurement-agent", "session_id": "s-991",
  "tool": "hr_export_db", "action": "read", "resource": "hr/salaries.xlsx",
  "data_class": "hr", "sensitivity": 3, "destination": null, "bytes_out": 0,
  "taint": [{"source": "supplier_invoice.pdf", "ts": "2026-10-23T08:09:02Z", "kind": "document"}],
  "chain": [], "manifest_version": 3, "token_id": "tok-5521"
}
```

4. Decision returned to the gateway

```
{
  "event_id": "7c1e...", "decision": "deny",           // allow | step_up | restrict | deny
  "score": 91, "tier": "isolate",                      // observe | step_up | restrict | isolate
  "reasons": [ {"signal": "role_violation", "points": 35, "text": "hr data not allowed for role"},
               {"signal": "taint_flow", "points": 25, "text": "3 min after untrusted PDF read"},
               {"signal": "sensitivity", "points": 15, "text": "restricted payroll data"} ],
  "alert_id": "A-9421"
}
```

5. HTTP API (v1)

Method and path	Purpose
POST /v1/tool-calls	Gateway submits an event, receives the decision (inline, target p95 under 10 ms)
GET /v1/agents/{agent_id}/risk	Current score, tier, active restrictions
GET /v1/alerts?status=&tier;=	List alerts, newest first
GET /v1/alerts/{alert_id}	Full alert: events, reasons, delegation chain, response log
POST /v1/alerts/{alert_id}/feedback	Analyst marks false_alarm or confirmed (feeds tuning)
POST /v1/approvals/{approval_id}	Human approves or denies a paused action
PUT /v1/manifests/{role}	Upload a new signed manifest version; rejected if signature invalid
POST /v1/agents/{agent_id}/release	Lift isolation after review (needs analyst role)
GET /healthz	Liveness and readiness

6. Rules

- All endpoints need mutual TLS or a service token; dashboard users need RBAC (viewer, analyst, admin).
- Responses use stable error codes: 400 invalid event, 401 unauthenticated, 403 forbidden, 409 manifest version conflict.
- Tokens and secrets are never stored in events. Payload bodies are stored masked (see Privacy doc).
- Publish the full OpenAPI file at `docs/openapi.yaml` once Phase 1 starts.